TollgateRAG: Auditable Pre-Generation Risk Gating Using Authority-Claim and Verified-Anchor Conflict Signals for Retrieval-Augmented Generation

Author: [Your Name] | **Affiliation:** [University / Independent] | **Contact:** [Email] **Code:** [GitHub link]

Abstract

Retrieval-augmented generation (RAG) pipelines usually place whatever they retrieve into the model's context. Existing defenses address this with injection-phrase filters, trust scores, or cryptographic provenance, but a document that contains no injection phrasing and simply *claims the authority to change policy* is poorly handled by injection filters, while a blunt trust filter that blocks every unverified document discards harmless content. We present TollgateRAG, a lightweight gate between retrieval and generation that scores each retrieved document on five transparent signals and decides accept, warn, or reject. Two signals are the focus: an **unauthorized authority-claim** signal, which penalizes unverified sources that assert policy authority, and a **verified-anchor conflict** signal, which checks an unverified document against the entire set of verified documents and flags it when it covers the same topic but relaxes a constraint the verified document imposes. Every decision is logged with reasons, and flagged documents enter a human review queue. On a small synthetic corpus (13 documents, 11 queries) that includes 6 adversarial and 2 benign unverified documents, the full gate rejected 88.9% of adversarial retrievals with 0% false positives on benign unverified and verified documents, and reduced the fraction of queries whose final context contained an adversarial document from 100% (plain RAG) to 27.3%. A trust-label-only filter blocked all adversarial documents but also rejected 100% of benign unverified documents, and an injection-keyword filter rejected only 22.2%. We also report negative findings: an evasive attack with no cue words is never blocked, and the reject decision is sensitive to its threshold. Because the corpus is small and the adversarial documents were authored with knowledge of the detectors, the results demonstrate the mechanism and its failure modes rather than real-world robustness. We release the implementation, evaluation harness, and audit tooling.

Keywords: retrieval-augmented generation, knowledge poisoning, prompt injection, provenance, risk gating, auditability

1. Introduction

RAG systems ground language-model answers in retrieved documents, which makes the retrieval corpus an attack surface: a few malicious or mistaken documents can steer an answer [PoisonedRAG]. Defenses fall into several families, including filtering of suspicious text, trust- and provenance-weighted retrieval, and architectural isolation of instructions from data.

We focus on a specific gap. Consider an internal policy assistant. An attacker (or a careless author) uploads a note titled "Updated Travel Policy Memo" saying that, effective immediately, an approval has been removed and receipts are no longer required. The note contains no instruction aimed at the model, so injection-phrase filters do not fire. Yet it is exactly the kind of document that should not override verified policy. Two observations motivate this work:

1. **Authority is conditional on source.** A verified policy document may say "effective immediately"; an unverified upload may not. Authority language from an unverified source is itself evidence of risk.
2. **A verified corpus is a reference.** Whether or not the verified policy was retrieved for this query, an unverified document that loosens its constraints on the same topic is suspicious.

Our contributions are:

1. Two content-based risk signals conditioned on source trust: *unauthorized authority claim* and *verified-anchor conflict*, combined with trust, freshness, and injection signals in a transparent weighted score with an accept/warn/reject gate.

2. An evaluation design that separates adversarial, benign-unverified, low-quality, and verified documents, so false positives are measured, with a context-level contamination metric and comparison to trust-only and injection-only baselines.
3. An honest account of failure modes: an evasive attack, threshold brittleness, and the limits of a small self-authored corpus.
4. An open reference implementation with audit logging, a human review queue, and spreadsheet export.

We do not claim to be the first provenance- or risk-aware RAG defense; see Section 2.

---

2. Related Work

Poisoning attacks and corpus-level defenses. PoisonedRAG showed that injecting a few crafted texts into a knowledge base can control RAG answers [Zou et al., USENIX Security 2025]. TrustRAG [arXiv:2501.00879] proposes training-free filtering of malicious content through clustering and model self-assessment. TollgateRAG instead makes a per-query, per-document decision with explicit reasons and conditions it on verified reference documents.

Provenance-based defenses. RAGShield [arXiv:2604.00387] applies supply-chain provenance ideas to RAG with cryptographic document attestation, trust-weighted retrieval, a taint lattice with cross-source contradiction detection, auditable citations, and NIST 800-53 mapping. It is considerably more comprehensive than our system and its provenance is cryptographically verified, whereas our trust labels are self-declared. Our contribution is narrower: a lightweight, explainable scoring layer and an evaluation that measures false positives. TriShieldRAG [arXiv:2607.23838] uses three independent checks and re-weights retrieved documents by provenance and consistency. A recent layered-defense preprint studies independently switchable layers for ablation [preprints.org 202609.2192], which overlaps with our ablation methodology.

Security surveys and hybrid defenses. A Springer survey of threats to retrieval- augmented LLM agents introduces a hybrid defense called AegisRAG-RADMS covering secure retrieval, injection detection, and tool I/O controls [Discover Artificial Intelligence, doi:10.1007/s44163-026-01726-x]. It addresses a broader scope (including tools) than our retrieval-to-generation gate.

Provenance and risk at the memory/action level. MAP-Graph [arXiv:2608.10509] combines provenance-aware shared memory with risk-sensitive action gating for multi-agent workflows. Query-aware source-risk triage [arXiv:2609.16564] examines source relationships after retrieval and assigns pass/contextualize/exclude/review actions, without downstream answer generation. Our work differs in focusing on authority claims and anchor conflict against a verified set, and on measuring false positives against benign unverified content.

Positioning. The combination we study, trust-conditioned authority-claim detection plus conflict against the full verified set, evaluated against benign unverified documents, is, to our knowledge from the sources reviewed, not isolated in this form. Given how active this area is, we make no priority claim.

---

3. Method

Setting. A corpus has documents with a source label, a trust level (verified, unverified, unknown), a date, and text. Given a query, the retriever returns the top-k candidates. A set of *verified anchors* is the subset of the corpus labeled verified.

Signals (each in [0, 1], higher is riskier):

Signal	Definition	Weight
trust_level	verified 0.05, unverified 0.55, unknown 0.80	0.25
freshness	document age over a 730-day horizon	0.10
injection	model-directed instruction phrases ("ignore all previous instructions")	0.30

Signal	Definition	Weight
authority_claim	unverified source containing authority phrases ("effective immediately", "supersedes", "no longer required"); zero for verified sources	0.15
anchor_conflict	unverified source sharing at least 3 salient terms and 12% term overlap with a verified anchor, containing relaxation cues ("removed", "regardless", "no approval") while the anchor contains constraint cues ("required", "must", "capped", "approval"); dollar figures that disagree with the anchor add to the score	0.20

The overall risk is the weighted sum. The gate rejects at risk >= 0.45, warns at >= 0.25, and accepts otherwise. Accepted and warned documents are ordered by risk and the top three form the context; warned documents are labeled low-confidence in the prompt. Rejected and warned documents are appended to a human review queue, and every decision with its sub-scores and reasons is written to a JSONL audit log.

Thresholds and weights were fixed before the threshold sweep but were not calibrated on held-out data.

---

4. Experimental Setup

Corpus. 13 synthetic documents about internal company policy: 4 verified; 2 benign unverified (practical tips consistent with policy); 1 low-quality (an outdated forum post with wrong figures); and 6 adversarial: one obvious injection, four "policy relaxation" notes with no injection phrasing, and one *evasive* document that states false dollar figures and a false default fare class without any relaxation, authority, or injection cue. Labels are in `data/labels.json`.

Queries. 11 queries on travel, remote work, account security, and international travel, including two benign how-to queries.

Retrieval. TF-IDF vectors in a Chroma store, top-6 candidates, top-3 final context. Generation is offline extractive for the reported numbers, so no LLM judgment is involved.

Metrics. Adversarial reject rate (per retrieval event); benign and verified false- positive rates; contamination (fraction of queries whose final context contains at least one adversarial document); adversarial documents in context.

Baselines. Plain RAG; trust-label-only (reject all non-verified); injection-keyword- only; a 3-signal scorer (trust + freshness + injection, same weights renormalized).

---

5. Results

5.1 Main comparison

Policy	Adv. reject	Benign FP	Verified FP	Contamination	Adv. docs in context
Plain RAG	0%	0%	0%	100% (11/11)	17
Trust-label only	100%	**100%**	0%	0%	0
Injection-keyword only	22.2%	0%	0%	100%	17
3-signal scorer	22.2%	0%	0%	100%	12
TollgateRAG (5 signals)	**88.9% (32/36)**	**0% (0/5)**	**0% (0/21)**	**27.3% (3/11)**	**3**

The trust-only filter achieves perfect adversarial blocking only by rejecting every unverified document, including both benign ones; it offers no way to use unverified content safely. The injection-only and 3-signal scorers miss the policy-relaxation documents, which carry no injection phrasing. The full gate rejected all 4 relaxation notes and the

obvious injection document on every retrieval, and rejected none of the benign unverified or verified documents. The four retrievals that were never rejected are all the evasive document. The low-quality forum post was warned in 4/4 retrievals; its risk (0.438) sits just under the reject threshold, so it is also threshold-sensitive.

Average end-to-end latency was 37.7 ms in offline mode, dominated by retrieval; LLM generation time is additional.

5.2 Ablation

Removing one dimension and renormalizing the remaining weights:

Configuration	Adv. reject	Contamination	Adv. docs in context
Full model	88.9%	27.3%	3
without trust_level	52.8%	54.5%	6
without freshness	88.9%	27.3%	3
without injection	88.9%	27.3%	3
without authority_claim	22.2%	63.6%	7
without anchor_conflict	22.2%	63.6%	7

At the default thresholds neither new signal alone is sufficient: removing either drops the reject rate to 22.2%, so the two act jointly with the trust prior. Freshness and injection are not needed on this corpus beyond the one obvious injection document, which is also caught by anchor conflict. Because weights are renormalized, removal also shifts the scale of the remaining scores, so the table should be read as indicative.

5.3 Threshold sensitivity

Sweeping the reject threshold (warn = 0.55 x reject) shows the reject decision is **brittle**. Subtle adversarial documents score between 0.46 and 0.49. For reject thresholds from 0.25 to 0.45 the adversarial reject rate is 88.9%, but at 0.50 to 0.60 it falls to 22.2%, and at 0.65 or above it is 0%. In all cases from 0.25 to 0.60 these documents are still *flagged* (warn or reject) at 88.9% or more, so the ranking is informative even when the reject action is not. Lower thresholds (0.20) separate the classes perfectly on this corpus (100% adversarial reject, 0% benign reject), because benign unverified documents score about 0.14. We do not treat this as evidence, because 13 documents cannot support threshold calibration and the choice could simply overfit.

---

6. Limitations

1. **Small, self-authored corpus.** The adversarial documents were written with knowledge of the cue lists. The 88.9% figure is likely optimistic and should not be read as robustness against a real attacker.
2. **Evasive attacks succeed.** The evasive document is never blocked and accounts for all contaminated queries. Cue-based detectors are bypassed by phrasing that avoids the cues; a numeric-only mismatch contributes too little risk.
3. **Threshold brittleness** (Section 5.3), with no held-out calibration.
4. **Self-declared trust labels.** An attacker who controls the label defeats the trust and authority signals. Cryptographic attestation as in RAGShield addresses this and is complementary.
5. **English-only, keyword-based detectors** that paraphrase or translation can evade.
6. **No answer-quality evaluation** with an LLM judge, and TF-IDF retrieval only.
7. **No adaptive attacker** and no gating of multi-step agent actions.

7. Future Work

Held-out evaluation on an established poisoning benchmark; learned classifiers for authority and relaxation; numeric and entity claim verification against anchors; validation-split threshold calibration with confidence intervals; adaptive attackers; answer-quality metrics; and extension of the gate to tool calls.

8. Conclusion

A gate that treats authority language from unverified sources as risk, and checks unverified documents against the verified corpus, catches a class of attacks that injection filters miss while avoiding the false positives of a blunt trust filter, on a small controlled corpus. The same experiments expose an evasion path and a fragile reject threshold, which define the work needed before any robustness claim.

References

1. Zou et al. PoisonedRAG: Knowledge Corruption Attacks to Retrieval-Augmented Generation. USENIX Security 2025.
2. TrustRAG: Enhancing Robustness and Trustworthiness in RAG. arXiv:2501.00879.
3. Patil. RAGShield: Provenance-Verified Defense-in-Depth Against Knowledge Base Poisoning in Government RAG Systems. arXiv:2604.00387.
4. Mohanty et al. TriShieldRAG: A Three-Ring Defense-in-Depth Framework Against Knowledge Corruption in RAG. arXiv:2607.23838.
5. End-to-end security threats and defenses in retrieval-augmented LLM agents (introduces AegisRAG-RADMS). Discover Artificial Intelligence, doi:10.1007/s44163-026-01726-x.
6. MAP-Graph: Provenance-Aware Shared Memory for Multi-Agent Workflows. arXiv:2608.10509.
7. Query-Aware Source-Risk Triage for Retrieval-Augmented Generation. arXiv:2609.16564.
8. Apurba et al. Defending Retrieval-Augmented Intrusion Detection Against Knowledge Poisoning and Prompt Injection. arXiv:2608.08100.
9. Layered provenance-aware RAG defense with independently switchable layers. preprints.org 202609.2192.

Verify each reference's authors, venue, and details before submission; entries above were identified from search results and may be incomplete.

Appendix A: Reproducibility

```
pip install -r requirements.txt
python -m tollgaterag.ingest
python -m tollgaterag.eval        # Section 5.1
python -m tollgaterag.ablation    # Sections 5.2 and 5.3
python -m tollgaterag.excel_export
```